Gestión de mecanismos de autenticación resistente al *phishing*

Síntesis: Configuración y validación de autenticación resistente al *phishing*

La configuración de mecanismos de autenticación resistente al *phishing* exige articular correctamente la parte confiable, el origen, los desafíos, los parámetros criptográficos, el registro de credenciales y la verificación servidor. WebAuthn y FIDO2 permiten sustituir secretos compartidos por credenciales de clave pública vinculadas con el servicio legítimo, pero su eficacia depende de que la implementación compruebe *challenge*, origen, RP ID, estado de la credencial, presencia o verificación del usuario y firma antes de establecer una sesión. El almacenamiento debe limitarse a la información necesaria para validar y administrar credenciales, preservando claves privadas y factores biométricos en el ámbito del autenticador y aplicando minimización a identificadores y registros técnicos. El ciclo de vida completa esta visión al incorporar enrolamiento, credenciales adicionales, recuperación, sustitución, revocación y desactivación como procesos sujetos a controles equivalentes al nivel de protección del mecanismo principal.

La validación convierte la configuración en evidencia. Mediante criterios de aceptación definidos previamente, pruebas funcionales y negativas permiten comprobar que el mecanismo responde correctamente tanto en el flujo esperado como ante origen no autorizado, desafíos inválidos o repetidos, credenciales no válidas, fallos de firma y estados revocados. La trazabilidad entre requisitos, casos, resultados y evidencias facilita identificar limitaciones, fallos de configuración y recomendaciones de seguridad. De este modo, el aprendizaje integra implementación y análisis crítico: no basta con habilitar *passkeys* o un autenticador criptográfico; se requiere demostrar que el servicio mantiene la vinculación con el verificador, resistencia a repetición, intención de autenticación cuando corresponda y procedimientos de recuperación coherentes con el riesgo y con los estándares técnicos aplicables.

